

匿名网络中的流量分析与滥用检测研究：从 Tor 网络到匿名化僵尸网络

梁峻玮 田丰睿 李青宇
PB23071341 PB23071318 PB23071316

2026 年 5 月 28 日

摘要

在此撰写摘要。

1 引言

1.1 研究背景与动机

随着 TLS、HTTPS 等加密协议的普及，网络通信内容的机密性已经在很大程度上得到保护。然而，内容加密并不等价于通信隐私的充分保护。即使攻击者无法解密具体载荷，通信双方的网络位置、连接时间、包长分布、方向序列、突发模式以及访问频率等元数据仍可能暴露用户行为和通信关系。Sasy 和 Goldberg 将这类问题概括为元数据保护通信系统（metadata-protecting communication systems, MPCs）的核心目标，即不仅要隐藏消息内容，还要尽可能削弱攻击者对发送者、接收者及二者关联关系的推断能力 [1]。从这一角度看，匿名网络并不是传统加密通信的替代品，而是在内容机密性之外进一步缓解通信关系泄露和流量侧信道的一类协议与系统机制。

匿名通信研究最早可以追溯到 Chaum 提出的 Mix 网络。该工作通过批处理、重排序和级联 Mix 打破输入消息与输出消息之间的对应关系，奠定了匿名通信对抗流量分析的基本范式 [2]。随后，洋葱路由进一步将匿名通信推向低延迟交互式场景，Tor 作为第二代洋葱路由系统，通过多跳电路、分层加密、目录服务和汇合点机制，在可用性、效率和匿名性之间作出工程化折中，成为目前最具代表性的匿名通信网络之一 [3]。这种设计使得单个中继难以同时获知通信源和通信目的，但低延迟交互式通信也保留了较多可观测的流量形状特征，为后续的网站指纹识别、流量相关和去匿名化攻击留下了空间。

近年来，匿名网络研究的重点逐渐从单纯构造匿名通信机制，转向围绕真实部署环境下的攻防对抗、可用性约束和安全边界展开。一方面，攻击技术不断利用加密流量中的时序和方向模式提升推断能力。例如，Shen 等人针对 Tor 网站指纹防御提出鲁棒流量表示方法，说明已有填充类防御仍可能保留可被学习的结构性泄露 [4]。Zhao 等人进一步将 Tor 指纹攻击推进到细粒度网页级识别，表明攻击目标已经从“访问了哪个站点”扩展到“访问了站点中的哪个页面” [5]。另一方面，真实环境评估也逐渐受到重视，Jansen 等人通过真实 Tor 流量轨迹构建数据集，指出以往基于合成数据的评估可能难以充分反映开放世界中的访问分布、基础率和会话复杂性 [6]。这些工作共同表明，匿名网络的安全性不能仅在理想化协议模型中讨论，而必须结合真实流量、真实用户行为和实际部署约束进行分析。

匿名网络的另一重要特征是其双重用途。一方面，它为新闻工作者、研究人员、政治异见者和普通用户提供了规避审查、保护访问隐私和降低追踪风险的工具。另一方面，匿名性也可能被恶意行为者利用，用于隐藏钓鱼站点、暗网服务、命令与控制（Command and Control, C&C）基础设施以及僵尸网络运营者的真实位置。因此，匿名网络研究不仅需要回答“如何提升匿名性”，还必须进一步讨论“如何在不动摇合法匿名性的前提下识别和治理滥用”。这正构成了本文从匿名网络基础、Tor 网络攻防到僵尸网络匿名化与检测进行系统调研的主要动机。

1.2 研究范围与思路

本文围绕“匿名网络、Tor 网络与僵尸网络”这一主题展开调研，聚焦于与网络安全协议最密切相关的三类问题：匿名通信机制如何隐藏通信关系，Tor 网络在真实部署中面临哪些流量分析与去匿名化威胁，以及僵尸网络等恶意活动如何利用匿名网络隐藏基础设施。换言之，本文关注的核心并非单纯的匿名通信技术介绍，而是匿名网络在协议设计、流量侧信道、攻防对抗和滥用检测之间形成的系统性安全问题。

在匿名通信基础方面,本文首先从元数据保护通信系统的视角出发,梳理匿名通信所试图保护的对象,包括发送者身份、接收者身份、通信双方关联关系以及多次通信行为之间的不可链接性 [1]。在此基础上,本文比较 Mix 网络、洋葱路由和 DC-Nets 等代表性技术路线。Chaum 提出的 Mix 网络通过批处理和重排序降低输入、输出消息之间的可链接性 [2],而 Tor 所代表的低延迟洋葱路由则通过多跳电路和分层加密支持交互式匿名访问 [3]。两类技术分别体现了匿名通信设计中的不同取舍。前者通常具有更强的流量混淆能力,但延迟和可部署性成本较高。后者更适合 Web 浏览等交互式场景,却更容易暴露包长、方向和时序等可被学习的流量特征。

在 Tor 网络攻防方面,本文重点讨论低延迟匿名网络在真实环境下面临的攻击与防御问题。近年来,网站指纹识别、流量相关攻击和针对洋葱服务的去匿名化技术不断发展,使得攻击者即使无法解密通信内容,也可能通过加密流量的形状特征推断用户访问目标或关联通信双方。与此相对应,流量填充、流量整形、对抗式防御和差分隐私机制被用于削弱流量侧信道,但这些防御通常会引入额外带宽、延迟或部署复杂性。因此,本文在研究 Tor 攻防技术时,不仅关注具体攻击或防御方法本身,也关注其威胁模型、评估数据集、现实可部署性和安全性的权衡。

在僵尸网络匿名化与检测方面,本文将 Tor 等匿名网络视为一种可能被滥用的基础设施,分析其在隐藏 C&C 服务器、规避追踪和提高恶意活动韧性方面的作用。与传统僵尸网络检测相比,匿名网络环境下的检测问题更加复杂:防御者既需要识别恶意流量和匿名化 C&C 行为,又必须避免破坏合法用户的匿名通信需求。因此,本文将僵尸网络部分置于匿名网络双重用途的框架下讨论,重点分析隐私保护与安全治理之间的张力,而不是泛泛介绍僵尸网络分类或恶意软件传播过程。

1.3 论文组织结构

本文后面的章节组织如下:

第二章介绍匿名网络技术基础,首先界定匿名通信所保护的对象和典型威胁模型,随后梳理 Mix 网络、洋葱路由、DC-Nets 等代表性技术路线,并从匿名性、时延、带宽开销和可部署性等维度分析不同机制之间的权衡关系,为后续讨论 Tor 网络攻防提供概念基础。

第三章以 Tor 网络为核心,首先介绍其系统架构、通信电路和洋葱服务机制,随后围绕网站指纹识别、流量相关攻击、带宽操纵攻击和洋葱服务去匿名化等方向总结近年来的攻击技术进展,并进一步分析流量填充、流量整形和协议层防御等对抗方法的有效性与局限性。

第四章讨论僵尸网络对匿名网络的利用及其检测问题。首先概述僵尸网络的基本架构与 C&C 通信模式,然后重点分析恶意活动如何借助 Tor 洋葱服务隐藏控制基础设施,并从流量特征、行为模式和机器学习检测等角度梳理匿名环境下的检测方法及其挑战。

第五章在前述分析基础上进行系统化讨论,进一步总结匿名网络、Tor 网络与僵尸网络之间的技术关联,提炼匿名通信系统面临的核心矛盾,包括低延迟可用性与抗流量分析能力之间的矛盾、隐私保护与滥用治理之间的矛盾,以及真实部署评估与理想化安全模型之间的差距。

第六章对全文进行总结,并展望匿名网络攻防研究在真实流量测量、可部署防御、隐私保护型滥用检测和安全治理机制等方面的未来发展方向。

2 匿名网络技术基础

匿名网络的核心目标并不是单纯加密通信内容,而是在通信内容已经受到加密保护的基础上,进一步隐藏通信双方的身份、通信关系以及由流量模式暴露出的行为特征。匿名通信系统关注的是网络层和流量层的元数据泄露问题,包括谁在通信、与谁通信、何时通信以及多次通信行为之间是否可以被关联。Sasy 和 Goldberg 指出不同匿名通信机制在隐私保证、系统假设和可部署性方面存在显著差异 [1]。因此,在分析 Tor 网络及其攻防技术之前,有必要先明确匿名通信的保护目标、攻击者能力以及主要技术路线。

本章围绕匿名网络的基础机制展开,从发送者匿名性、接收者匿名性和通信不可链接性三个层面界定匿名通信的基本目标,并结合被动监听、恶意中继、局部网络观察和全局攻击者等模型说明匿名网络所面临的典型威胁。同时,梳理了 Mix 网络、洋葱路由和 DC-Nets 等代表性技术路线,比较它们在匿名性、延迟、带宽开销和部署复杂度方面的差异。本章在最后也进一步讨论了匿名网络设计中的核心权衡,即强匿名性通常需要引入延迟、填充或覆盖流量,而低延迟和高可用性又会暴露更多可被流量分析利用的统计特征。

2.1 匿名通信的目标与威胁模型

匿名通信系统试图保护的對象可以分为三个层次。第一是发送者匿名性，攻击者即使能够观察网络中的部分通信流量，也难以确定某条消息或某次连接究竟由哪个用户发起。第二是接收者匿名性，通信目标或服务提供方的身份不应轻易暴露给观察者。第三是不可链接性，攻击者难以将同一用户的多次访问、同一会话中的多个流量片段，或某个用户与某个访问目标之间建立稳定关联。相比传统加密协议，匿名通信更关注通信关系和访问模式等元数据，这些元数据即使在内容加密后仍然可能通过包长、方向、时序和突发结构泄露用户行为。

早期匿名通信研究已经意识到通信关系本身可能成为敏感信息。Chaum 提出的 Mix 网络通过批处理、重排序和转发打破输入消息与输出消息之间的对应关系，从而降低观察者对发送者和接收者关系的推断能力 [2]。洋葱路由则转向低延迟交互式通信场景，Tor 通过多跳电路和分层加密使得单个中继节点无法同时获知通信源和通信目的 [3]。这两类机制体现了匿名通信目标的不同侧重，Mix 网络更强调打破端到端流量关联，洋葱路由则更强调在可接受延迟下提供可部署的匿名访问能力。

匿名通信系统的安全性高度依赖威胁模型。最基本的攻击者是本地被动观察者，例如互联网服务提供商、局域网监听者或出口链路上的监测者。此类攻击者不修改流量，但可以记录连接时间、包长序列和流量方向，并据此进行网站指纹识别或访问行为推断。更强的攻击者可能控制匿名网络中的部分节点。例如在 Tor 中，恶意入口节点可能观察用户进入网络的流量，恶意出口节点可能观察离开匿名网络的明文或目标连接信息，而多个恶意节点的协同则可能增加端到端关联风险。对于 Mix 网络而言，部分混合节点或 provider 被攻陷也会削弱匿名集规模和流量混合效果。

进一步而言，局部网络攻击者可以观察多个自治系统、交换点或网络路径上的流量，从而尝试进行跨链路相关分析。全局被动攻击者则被假设能够观察整个网络中的所有输入和输出流量，是匿名通信研究中常用但较强的理论模型。在全局观察条件下，低延迟匿名网络尤其脆弱，因为系统为了保证交互性通常不会引入足够大的延迟、批处理或覆盖流量来完全打散输入输出时序关系。与被动攻击者相比，主动攻击者还可以延迟、丢弃、注入或操纵数据包，通过人为改变流量模式来放大可观测特征，甚至诱导特定路径选择或服务行为。

因此，匿名网络的安全性不能脱离具体攻击者能力进行讨论。同一系统在不同威胁模型下可能呈现出完全不同的安全边界，在局部被动观察者模型下，Tor 可以通过多跳电路隐藏用户与目标之间的直接关联。但在更强的流量相关或全局观察模型下，其低延迟设计仍可能暴露端到端统计相关性。类似地，Mix 网络通过延迟、重排序和覆盖流量增强匿名性，但这些机制又会带来额外时延、带宽和部署成本。匿名通信系统的设计本质上是在攻击者能力、隐私保证和系统可用性之间寻找平衡，这也构成了后续比较不同匿名技术路线的基础。

2.2 匿名网络的主要技术路线

围绕通信关系隐藏这一目标，匿名网络形成了多条技术路线。其中，Mix 网络和洋葱路由是最具代表性的两类机制。前者通过延迟、批处理和重排序削弱输入输出流量之间的对应关系，通常能够提供更强的流量混淆能力，后者则通过多跳转发和分层加密隐藏通信路径，在牺牲部分抗流量分析能力的同时获得较低延迟和较高可部署性。除此之外，DC-Nets、匿名广播、匿名凭证和私有用户发现等机制也从不同角度扩展了匿名通信的应用边界。

Mix 网络是匿名通信研究的经典起点。Chaum 最早提出的 Mix 机制通过收集一批输入消息、剥离加密层、打乱顺序并转发输出，使外部观察者难以建立输入消息与输出消息之间的对应关系，在级联 Mix 中，只要路径上至少存在一个诚实 Mix 节点，就可以在在一定程度上保护通信关系不被追踪 [2]。这一思想的核心在于主动改变流量的时序和顺序结构，而不是仅依赖内容加密隐藏通信信息。因此，Mix 网络天然适合对抗强观察者和流量相关攻击，但代价是引入额外排队延迟、批处理等待和系统同步开销，使其早期更适合电子邮件等非实时通信场景。

为缓解传统 Mix 网络延迟较高、难以支持交互式应用的问题，后续研究尝试将 Mix 机制推向低延迟和可部署方向。Loopix 采用 Poisson mixing、分层拓扑和自注入 loop 覆盖流量，在保留 Mix 网络输入输出混淆能力的同时支持双向匿名通信 [7]。Rahimi 等人提出 LARMix，通过延迟感知路由和地理位置聚类降低 Mix 网络中的传播延迟，使 Mix 网络从“强匿名但高延迟”的理论机制进一步走向可用性优化 [8]。LAMP 进一步针对 LARMix 在大规模网络下计算开销较高、难以直接部署的问题，提出轻量级路由策略，在降低端到端延迟的同时显著减少路由计算成本 [9]。这些工作说明，现代 Mix 网络研究已经不再只关注匿名性本身，而是转向匿名性、延迟、计算开销和部署复杂度的联合优化。

除了路由层面的延迟优化, Mix 网络还需要考虑不同应用流量共同存在时的匿名性变化。Ben Guirat 等人提出 Beta-Mixing 分析框架, 研究连续 Mix 网络中不同延迟需求流量混合时的匿名性影响, 指出小规模流量类别在与大规模流量混合后可能获得更大的匿名集, 从而提升整体匿名性 [10]。这一结果表明, Mix 网络的匿名性不仅由单个节点或单条路径决定, 也与全网流量组成、延迟分布和覆盖流量策略密切相关。Oldenburg 等人提出 MixMatch, 对部署型 Mix 网络中的流匹配攻击进行研究, 说明即使系统引入混合、延迟和覆盖流量, 攻击者仍可能利用统计特征尝试关联输入输出流量 [11]。因此, Mix 网络虽然相较于低延迟洋葱路由具有更强的抗流量分析潜力, 但其安全性仍取决于具体流量模型、部署条件和攻击者观察能力。

洋葱路由则代表了另一类设计取向, 其更强调在低延迟条件下隐藏通信路径。基本思想是客户端选择一条由多个中继节点组成的路径, 并对消息进行多层加密, 每个中继节点只能解开属于自己的一层加密, 获知前一跳和后一跳, 却无法同时知道通信源和最终目的。Tor 是这一思想最成功的工程化实现。Dingledine 等人提出的第二代 Tor 通过递增式电路构建、固定大小 cell、目录服务、SOCKS 接口和汇合点机制, 使洋葱路由能够支持 Web 浏览等交互式应用, 并在匿名性和可用性之间取得可部署的折中 [3]。

然而, Tor 的低延迟设计也决定了它无法像高延迟 Mix 网络那样充分打乱输入输出时序关系。为了保证交互式体验, Tor 通常不会引入大规模批处理、长时间延迟或高强度覆盖流量, 因此包方向、包长序列、突发模式和会话长度等流量形状特征仍然可能被攻击者利用。这也是网站指纹识别、流量相关攻击和洋葱服务去匿名化攻击长期以 Tor 为主要研究对象的重要原因之一。

从协议基础来看, 洋葱路由的安全性不仅依赖路径选择和中继假设, 也依赖底层数据包格式与密码学构造。Sphinx 包格式被广泛用于洋葱路由和 Mix 网络场景, 其目标是在隐藏路径信息的同时支持逐跳处理和回复机制。Scherer 等人重新审视 Sphinx 的可证明安全性, 指出原有证明假设存在不足, 并在更严格的模型下给出修正分析 [12]。进一步地, 同一研究线还提出面向全局对手的可证明安全洋葱路由框架, 从服务设置、接收者信任、负载完整性和回复机制等维度刻画不同洋葱路由变体的安全边界 [13]。这些工作说明, 匿名网络的安全性不能只从系统架构层面理解, 也需要结合密码协议模型和攻击者能力进行形式化分析。

除 Mix 网络和洋葱路由外, DC-Nets 也提供了另一种匿名通信思路。Chaum 提出的 Dining Cryptographers 网络通过参与者之间共享随机比特并公开异或结果, 实现信息论意义上的发送者匿名性 [14]。这类机制在理论上提供很强的匿名保证, 但通常面临参与者规模、通信开销、碰撞处理和恶意参与者干扰等问题, 因此更适合小规模或特定安全需求场景。近年来, 匿名广播、私有用户发现和可问责匿名通信等方向也在继续发展。例如, Pudding 关注匿名网络中的私有用户发现问题, 试图避免用户查找过程泄露联系人关系 [15]。Gyges 则探索在匿名广播中引入可问责机制, 以缓解匿名通信被滥用后的追踪困难 [16]。这些工作表明, 匿名通信研究已经从单一的隐藏通信双方扩展到更复杂的系统功能, 如用户发现、滥用追责和应用层隐私保护。

不同匿名技术路线体现了不同的设计取舍, Mix 网络通过延迟、重排序和覆盖流量增强抗流量分析能力, 但需要承担额外时延和带宽开销。洋葱路由通过低延迟多跳转发实现大规模部署, 却保留了更多可被学习的流量形状特征。DC-Nets 和匿名广播机制能够提供更强的理论匿名性或特殊功能, 但往往受限于可扩展性和部署复杂度。正是这些差异, 使得匿名网络的研究不能停留在抽象安全定义上, 而需要进一步分析具体系统在真实网络环境中的攻击面、防御成本和可部署性。

2.3 匿名性、性能与可部署性的权衡

匿名网络的设计并不能单纯追求匿名性, 而需要在匿名性、时延、带宽开销、计算开销和部署复杂度之间进行折中。一般来说, 系统越希望抵抗强观察者和流量相关攻击, 就越需要引入延迟、批处理、重排序、填充或覆盖流量等机制。但这些机制又会降低交互性, 增加网络负载, 并影响用户持续使用的意愿。因此, 匿名通信系统的安全性不仅取决于协议是否能够在理论模型下隐藏通信关系, 还取决于这些保护机制能否在真实网络、真实设备和真实用户行为中被长期部署。

Mix 网络通过延迟和重排序削弱输入输出流量之间的统计对应关系, 因而更适合对抗强流量观察者, 但如果延迟过高, 系统就难以支持 Web 浏览、即时通信等交互式应用。Loopix、LARMix 和 LAMP 等工作正是在这一背景下尝试降低 Mix 网络的可用性成本。Loopix 通过 Poisson mixing 和覆盖流量将 Mix 网络推进到秒级延迟场景 [7], LARMix 通过延迟感知路由改善路径选择 [8], LAMP 则进一步降低大规模部署中的路由计算开销 [9]。

然而,降低延迟往往意味着系统会暴露更多可被学习的流量结构。对于 Tor 这类低延迟洋葱路由系统而言,其核心优势在于能够支持大规模、低门槛的交互式匿名访问,但为了保证可用性,Tor 不能像高延迟 Mix 网络那样充分打散端到端时序关系。因此,攻击者可以利用包方向、包长序列、突发模式和访问持续时间等特征进行网站指纹识别或流量相关分析。Shen 等人通过鲁棒流量表示绕过多种网站指纹防御 [4],Zhao 等人进一步将攻击粒度推进到细粒度网页级识别 [5],说明低延迟匿名网络在真实环境中仍然面临持续演化的流量侧信道风险。

针对流量侧信道,常见防御思路包括流量填充、流量整形、延迟注入和覆盖流量等。这些方法的共同目标是在不解密通信内容的情况下,削弱攻击者从流量形状中恢复访问行为或通信关系的能力。DeTorrent 通过对抗训练生成填充策略,在不延迟真实流量的前提下调度 dummy packets,以降低网站指纹和流量相关攻击的有效性 [17]。Maybenot 则将流量分析防御抽象为概率状态机框架,使 padding 和 blocking 策略能够在 Tor、TLS、QUIC 和 VPN 等不同通信场景中复用 [18]。防御研究正在从单一攻击场景下的专用算法,逐渐转向更通用、可组合和工程化的防御框架。

防御机制自身也会引入新的成本和边界条件。填充和覆盖流量会增加带宽消耗,延迟注入会影响交互体验,复杂的自适应防御还可能带来实现难度和部署兼容性问题。NetShaper 从差分隐私角度对网络侧信道进行流量整形,试图用形式化隐私参数刻画包大小和时序泄露的防护强度,但其设计同样需要在隐私保证、带宽开销和延迟成本之间进行参数化配置 [19]。匿名网络防御并不存在无成本的安全增强,任何削弱流量可区分性的机制,都必须以某种资源消耗、性能损失或系统复杂度为代价。

可部署性还与终端设备、网络环境和用户行为密切相关。Hugenroth 等人对智能手机上匿名网络的能耗进行测量,发现 Tor 持续运行的额外能耗相对有限,而持续发送覆盖流量的 Mix 类系统则更容易受到无线链路和设备能耗约束影响 [20]。匿名网络的实际可用性不能只从服务器端吞吐量或协议延迟评估,还必须考虑移动设备、电池消耗、网络波动和用户持续在线等现实条件。对于依赖大量覆盖流量或持续连接的系统而言,这些因素可能直接决定其能否被普通用户长期采用。

匿名网络的评估也受到数据集和实验设置的影响。许多网站指纹和流量分析研究依赖受控环境下采集的合成数据,而真实用户访问行为往往具有更复杂的访问分布、会话长度、并发请求和背景流量。Jansen 等人构建真实 Tor 流量轨迹数据集,指出合成数据与真实 Tor 使用之间存在显著差异 [6]。匿名网络攻防研究不能仅以理想化准确率或封闭世界实验作为结论依据,而应进一步关注开放世界环境、基础率问题、真实流量分布和长期部署后的攻击适应性。

匿名网络的核心矛盾可以概括为越强的匿名性通常需要越高的延迟、带宽和系统复杂度,而越好的交互性和可部署性又往往会暴露更多可被流量分析利用的统计特征。Mix 网络、洋葱路由和各类流量整形机制分别代表了不同的设计折中。正是这种安全目标与现实约束之间的张力,使得 Tor 网络成为匿名通信研究中最具代表性的系统,它在真实世界中获得了广泛部署,同时也集中暴露了低延迟匿名网络在网站指纹、流量相关、洋葱服务安全和匿名化滥用治理方面的典型问题。

3 Tor 网络攻防技术

Tor (The Onion Router) 是当前部署规模最大、研究最充分的低时延匿名通信系统 (low-latency anonymous communication system) 之一。自第二代洋葱路由系统被提出以来,Tor 逐步形成了由客户端 (Client)、志愿者中继 (Relay)、目录基础设施 (Directory Infrastructure)、出口策略 (Exit Policy)、洋葱服务 (Onion Service, 旧称 Hidden Service) 与可插拔传输 (Pluggable Transport) 共同构成的复杂匿名通信生态 [3, 21]。从安全研究视角看,Tor 并非单一密码协议,而是一个同时受到密码学设计、互联网路由、流量统计学习、系统资源管理与审查对抗共同影响的大规模网络系统。因此,围绕 Tor 的攻防研究也呈现出明显的多层化特征:攻击侧从早期的节点控制与流量关联,发展到深度学习网站指纹、自治系统/边界网关协议级观测 (AS/BGP-level observation)、洋葱服务会话关联、带宽膨胀和目录共识破坏;防御侧则从链路层协议加固、守卫节点策略和目录共识机制,扩展到流量填充、路由感知路径选择、隐私保护测量、抗审查传输和面向洋葱服务的性能优化。本节按照“架构基础-攻击演进-防御对抗-态势分析”的逻辑,对 Tor 网络攻防技术进行系统化梳理,并为后续讨论匿名网络与僵尸网络隐匿通信之间的关系提供技术基础。

3.1 Tor 网络架构

本小节首先描述 Tor 的基础架构与关键组件，再按照目录共识、链路构建和洋葱加密三个核心协议流程说明 Tor 如何完成匿名通信，最后补充洋葱服务、可插拔传输与隐私保护测量等扩展机制。这样的组织方式与本节开头所列出的客户端、中继、目录基础设施、出口策略、洋葱服务和可插拔传输相对应，能够覆盖理解 Tor 后续攻防问题所需的主要架构基础。

3.1.1 系统组成与节点角色

Tor 的思想源于一代洋葱路由 (Onion Routing)。Syverson、Goldschlag 与 Reed 提出的匿名连接模型已经奠定了“发送方构造多层加密洋葱、每个中继只剥离一层并获得下一跳”的基本范式 [22]。Dingledine 等人提出的 Tor 则在此基础上完成了面向互联网部署的系统化重构：其核心目标不是提供绝对意义上的不可追踪性，而是在可接受时延和带宽开销下，使任一单点观察者难以同时获得通信双方身份 [3]。这种设计决定了 Tor 本质上属于低时延匿名系统，适合 Web 访问、即时通信和一般 TCP 应用，但并不承诺抵御能够同时观察全网入口与出口流量的全局被动攻击者 (Global Passive Adversary, GPA)。

Tor 网络由四类基础实体组成。第一类是**客户端 (Client)**，负责获取目录信息、选择路径、建立链路 (Circuit) 并将本地应用流量封装进 Tor 信元 (Cell)。第二类是**中继节点 (Relay)**，根据其在链路中的位置可分为守卫节点 (Guard Relay 或 Entry Relay)、中间中继 (Middle Relay) 和出口中继 (Exit Relay)。守卫节点直接连接客户端，能够看到用户 IP 地址但不知道最终访问目标；出口中继负责将流量发送至公网目标，能够看到目的站点及未加密应用层内容但不知道用户真实地址；中间中继只知道前后两跳，用于切断入口与出口之间的直接关系。第三类是**目录权威服务器 (Directory Authority)**，负责收集中继描述符、对网络状态进行投票并生成网络状态共识 (Network Status Consensus)。第四类是**目录缓存 (Directory Cache)**，通常由部分中继承担，负责缓存并向客户端分发共识文件、微描述符 (Microdescriptor) 和中继描述符，从而降低客户端对目录权威服务器的直接访问压力 [21]。目录权威服务器负责形成权威网络视图，目录缓存负责扩展分发能力，两者共同构成 Tor 路径选择之前的目录基础设施。

除上述基础实体外，Tor 还包含出口策略 (Exit Policy)、洋葱服务 (Onion Service) 和可插拔传输 (Pluggable Transport) 等重要机制。出口策略规定出口中继允许连接的目标端口和协议范围，影响客户端能否为特定目标选择某个出口中继。洋葱服务允许服务端隐藏自身网络位置，使客户端和服务端均通过 Tor 链路完成连接。可插拔传输则主要服务于抗审查场景，通过改变 Tor 流量的外部形态来降低被深度包检测 (Deep Packet Inspection, DPI) 直接识别和封锁的概率。由此可见，Tor 基础架构并非仅由三跳中继构成，而是由“目录发现-路径选择-链路传输-出口访问/洋葱服务-审查规避”共同组成的完整系统。

3.1.2 核心协议：目录共识、链路构建与洋葱加密

目录共识 (Directory Consensus)。Tor 客户端在建立通信前首先需要获得可信的网络视图。目录权威服务器周期性收集中继上传的服务器描述符 (Server Descriptor) 和微描述符，并对中继是否在线、可达、稳定、是否适合担任守卫或出口等状态进行投票，最终生成带有多方签名的网络状态共识 [21]。客户端下载并验证该共识后，可以获得中继身份、公钥摘要、地址、端口、带宽权重、出口策略摘要及 Guard、Exit、Stable、Fast 等标志位。现代 Tor 客户端通常并不需要下载完整服务器描述符，而是使用体积更小的微描述符共识和必要的微描述符，以降低启动和更新目录信息的带宽开销。目录共识的直接功能是提供路径选择所需的全网中继名录和权重信息，而不是在本节中展开其安全目的；目录权威和目录缓存的安全意义将在后文基础设施攻防中讨论。

链路构建 (Circuit Construction)。获得共识后，客户端按照带宽权重、角色约束、出口策略、守卫节点策略和路径选择规则，在本地选择一条通常由三跳组成的链路，即“客户端-守卫-中间-出口”。需要强调的是，客户端可以在本地规划完整路径，但协议交互并不会一次性把完整路径暴露给任一中继。Tor 采用增量式的望远镜式构建 (Telescoping Construction)：客户端首先与第一跳守卫节点完成认证密钥交换并建立第一段链路；随后通过已经建立的前缀链路向第二跳发送扩展请求；最后再经由前两跳将链路扩展至第三跳出口中继 [3, 21]。在该过程中，每个中继只知道自己的前一跳和后一跳，不

能单独恢复完整通信路径。链路建立完成后，多个应用层 TCP 流可以在同一链路上多路复用 (Stream Multiplexing)，从而降低频繁建路带来的性能开销。

洋葱加密 (Onion Encryption)。Tor 的密码学结构可以概括为“非对称握手建立每跳密钥，对称加密承担高频数据转发”。在链路创建阶段，客户端分别与链路上的每个中继协商独立会话密钥；在数据传输阶段，应用数据被切分为固定大小信元并进行多层对称加密。客户端发送方向上，数据依次使用出口、中间、守卫三跳密钥进行嵌套加密；沿路径转发时，每个中继只解开属于自己的一层并根据内部头部信息转发给下一跳。反向传输时，出口、中间、守卫依次增加加密层，客户端最终逐层解开。固定大小信元、多路复用 TCP 流和完整性校验共同降低了简单包长指纹和标签攻击风险，但并不能消除数据包方向、突发结构、时序间隔与连接持续时间等元数据泄露。因此，目录共识解决“有哪些中继可选”的问题，链路构建解决“如何逐跳建立匿名路径”的问题，洋葱加密解决“如何让单个中继只能看到局部转发信息”的问题，三者共同构成 Tor 匿名通信的核心协议基础。

3.1.3 洋葱服务、可插拔传输与真实网络测量

除访问公网服务外，Tor 还支持**洋葱服务 (Onion Service)**。洋葱服务允许服务端隐藏自身 IP 地址，并通过引入点 (Introduction Point) 与汇合点 (Rendezvous Point) 完成客户端和服务端的匿名连接。与普通出口链路相比，洋葱服务通常需要客户端侧三跳链路与服务端侧三跳链路共同参与，路径更长、交互轮次更多，因此在延迟、吞吐和可用性上面临更大压力。Winter 等人通过访谈、问卷和 .onion 查询数据研究发现，用户对洋葱服务的心理模型并不完整，对地址发现和站点认证机制存在明显不满，同时现实中还存在大量相似洋葱地址和钓鱼风险 [23]。这说明洋葱服务的安全问题不仅是协议问题，也包含可用性、身份认证和用户认知问题。

在审查环境中，Tor 还依赖**可插拔传输 (Pluggable Transport)** 隐藏或改变 Tor 流量的可识别特征。其基本思想是在客户端和桥接节点 (Bridge) 之间增加一层传输封装，使审查者难以仅凭 Tor 握手或流量格式识别 Tor 连接。Snowflake、WebRTC 封装和后续瞬时代理方案均属于这一方向。可插拔传输并不改变 Tor 内部的链路和洋葱加密语义，而是改善客户端进入 Tor 网络之前的可达性问题，因此它在系统架构中连接了匿名通信与抗审查通信两个研究脉络。

对真实 Tor 网络的理解还依赖**隐私保护测量 (Privacy-Preserving Measurement)**。Mani 等人基于 PrivCount 和 Private Set-Union Cardinality 对 Tor 进行测量，发现 Tor 日均用户规模可能显著高于传统估计，并观察到大量失败的洋葱地址查询 [24]。该类工作的重要意义在于：Tor 研究不能只停留在协议规范或小规模实验网络中，而必须在不伤害用户隐私的前提下理解真实流量、真实服务和真实攻击面。总体而言，3.1.1 至 3.1.3 分别覆盖 Tor 的实体组成、核心通信流程和扩展服务机制，能够构成后续讨论攻击面与防御机制的基础架构描述。

3.2 攻击技术分类与演进

Tor 攻击研究可以按照**攻击者观测位置与攻击目标**进行划分。观测位置包括客户端侧、入口侧、出口侧、洋葱服务侧、互联网路由层以及目录/带宽测量基础设施；攻击目标则包括识别访问网站、关联通信双方、发现或干扰洋葱服务、操纵路径选择以及破坏网络可用性。基于这两个维度，本文将现有攻击概括为四类：第一类是面向客户端访问行为识别的流量分析攻击 (Traffic Analysis)，典型代表是网站指纹；第二类是面向通信双方关系恢复的去匿名化攻击 (Deanonymization Attack)，包括端到端流关联、DNS 增强关联和 AS/BGP 级攻击；第三类是面向洋葱服务的发现、可用性和会话关联攻击；第四类是面向 Tor 生态基础设施的攻击，包括拒绝服务、带宽测量操纵、目录共识破坏和潜在的 Sybil 攻击 (Sybil Attack)。这种划分既对应攻击者所在的网络层次，也对应 Tor 希望保护的不同安全属性，因而能够较系统地概括近十年 Tor 攻防研究的主要脉络。

3.2.1 流量分析攻击：Website Fingerprinting 的深度学习化

网站指纹攻击 (Website Fingerprinting, WF) 试图在不破解 Tor 加密内容的情况下，仅利用包方向、突发长度、时间间隔和连接持续时间等元数据识别用户访问的网站或页面。2018 年前后，WF 研究发生了从手工特征工程向深度学习的转变。Sirinam 等人提出 Deep Fingerprinting (DF)，使用卷积神经网络直接学习 Tor 访问轨迹中的方向序列特征，在未防御流量和部分轻量级填充防御下取得了远

高于传统方法的准确率 [25]。这一结果表明, 固定大小信元只能削弱单包长度泄露, 无法消除流量突发结构中蕴含的站点特征。

随后研究进一步关注模型的数据效率和特征完整性。Bhat 等人提出 Var-CNN, 引入膨胀因果卷积和残差结构以捕捉长程时序依赖, 并将自动学习特征与统计特征融合, 证明深度 WF 攻击在低数据场景下仍具有较强能力 [26]。Rahman 等人的 Tik-Tok 则系统证明了时序信息并非噪声, 而是与方向特征互补的重要信号; 其方向-时序融合表示在未防御 Tor、WTF-PAD 和洋葱站点流量上均显著提升识别能力 [27]。到 2024 年, Zhao 等人提出 Oscar, 将问题从“识别网站”推进到“识别同一网站内部具体网页”, 通过多标签度量学习处理多页面混合和细粒度网页差异, 在大规模监控页与非监控页数据集上显著提升 Recall@5[5]。

综上, 流量分析攻击的演进体现出三个结论: 一是深度模型显著降低了攻击者对人工特征工程的依赖; 二是包方向、突发结构和时序信息共同构成稳定泄露源; 三是研究前沿正在从封闭世界网站分类转向开放世界、细粒度网页识别、多标签混合流量和跨时间泛化。这意味着 Tor 的内容加密并不等同于元数据隐藏, 低时延设计天然保留了可供统计学习利用的通信节奏。

3.2.2 去匿名化攻击: 流关联、DNS 泄露与 AS 级对手

当攻击者能够同时观察客户端到守卫节点的入口侧流量和出口节点到目的站点的出口侧流量时, 攻击目标便从“用户访问了哪类网站”升级为“某个用户是否正在访问某个具体目标”。Nasr 等人提出 DeepCorr, 利用深度学习模型学习 Tor 流量在多跳转发中的噪声和扰动模式, 从而对入口流和出口流进行端到端相关性判断 [28]。该工作的重要性在于, 它降低了流关联攻击对精心设计统计指标的依赖, 说明中等规模多点观察者也可能借助数据驱动模型提升去匿名化能力。

DNS 路径进一步扩大了流关联攻击的观测面。Greschbach 等人的 DefecTor 研究指出, Tor 出口节点对公共 DNS 解析器的选择存在集中化现象, 攻击者若能观察出口 DNS 请求, 便可将 DNS 信息与客户端网站指纹结合, 从而显著提升关联攻击效果 [29]。该工作提醒我们, Tor 的匿名性不仅取决于 Tor 覆盖网络本身, 还受出口侧 DNS 解析、目的站点部署和互联网基础设施集中化影响。

更底层的威胁来自自治系统级对手 (AS-level Adversary) 和边界网关协议级对手 (BGP-level Adversary)。AS 级攻击者不需要控制 Tor 中继, 只需位于客户端-守卫路径和出口-目的路径的共同自治系统上, 便可能被动关联两端流量。Sun 等人提出 Counter-RAPTOR, 系统分析主动 BGP 前缀劫持对 Tor 匿名性的影响, 说明攻击者可通过路由操纵使自身出现在入口或出口路径上 [30]。Gegenhuber 等人进一步利用 RIPE Atlas 长期测量不同国家客户端、Tor 入口路径和目标 AS 之间的关系, 展示了 AS 级流量关联风险的地域差异和带宽集中化效应 [31]。

综上, 去匿名化攻击的关键结论是: Tor 的三跳链路能够阻止单个中继同时获知通信双方, 但不能消除端到端流量模式和底层互联网路径所带来的相关性。攻击者的优势不一定来自破解加密, 而可能来自 DNS 解析集中化、互联网路由可见性、BGP 操纵能力或入口/出口两侧长期观测能力。因此, Tor 威胁模型已经从覆盖网络内部节点控制, 扩展到互联网基础设施层面的联合分析。

3.2.3 针对洋葱服务的攻击

洋葱服务因同时隐藏客户端和服务端位置, 长期被视为 Tor 中更强的匿名通信形态, 但其更长路径和更复杂握手也引入了新的攻击面。Winter 等人的用户研究表明, 洋葱服务在地址发现、服务认证和用户信任方面存在天然脆弱性, 攻击者可利用相似地址、过期链接和用户对 .onion 机制理解不足实施钓鱼或误导 [23]。这类问题并不直接破坏 Tor 密码协议, 却会在实际使用中削弱匿名服务的安全性。

在网络层, Lopes 等人针对洋葱服务会话提出基于滑动子集和 (Sliding Subset Sum, SUMo) 的流关联攻击, 面向客户端与洋葱服务之间的会话流量进行过滤、时间对齐和滑动窗口匹配 [32]。与普通出口链路相比, 洋葱服务路径更长、噪声更多、可能存在链路填充和多路复用, 因此过去常被认为更难关联; 该工作表明, 只要攻击者在合适位置获得足够观测能力, 仍可能通过高效统计匹配恢复会话关联关系。

综上, 洋葱服务的攻击面具有双重性: 一方面, 服务发现、地址认证和用户信任问题会在应用层削弱安全性; 另一方面, 长路径并不自动等价于强抗关联能力, 网络层攻击者仍可利用会话级流量特征进行关联。因此, 洋葱服务安全不能仅依赖“路径更长”这一直觉, 而需要将协议防护、用户可用性、服务发现、流量填充和 DoS 防御共同纳入设计。

3.2.4 基础设施攻击与最新研究进展

基础设施攻击关注的不是某条链路的瞬时匿名性，而是 Tor 网络维持可用性和可信路径选择所依赖的资源管理、带宽测量与目录共识。Jansen 等人提出的狙击手攻击 (Sniper Attack) 揭示了 Tor 早期拥塞控制和传输队列设计可被用于低成本拒绝服务 (Denial of Service, DoS)：恶意客户端或服务端通过操纵读取行为和 SENDME 机制，使目标中继积累大量未释放数据，最终耗尽内存并崩溃 [33]。该攻击的意义在于，DoS 不只是可用性威胁，还可能通过选择性排除守卫或出口节点改变用户路径选择，进而服务于去匿名化。相关实验大量依赖 Shadow 仿真框架，Jansen 等人关于 Tor 网络建模的方法论也成为后续安全评估的重要工具 [34]。

2023 年以来，研究焦点进一步转向带宽测量和目录共识机制。Sendner 等人提出 TorMult 带宽膨胀攻击 (Bandwidth Inflation Attack)，利用多个中继共享资源以及带宽测量流量可被识别的缺陷，使攻击者控制的节点在共识中获得高于真实能力的带宽权重，从而增加被选入用户链路的概率 [35]。这类攻击直接挑战了 Tor“按带宽加权选择路径”的基础假设。进一步地，Luo 等人针对目录协议提出短时 DDoS 破坏共识生成的研究，指出现有目录权威协议在网络同步假设上存在脆弱性，并提出基于部分同步模型的缓解方案 [36]。该工作揭示了 Tor 攻防正在从客户端流量层面扩展到目录、测量和共识协议本身。

综上，基础设施攻击说明 Tor 匿名性依赖的不仅是洋葱加密和路径分离，还包括中继资源管理、带宽权威测量、目录共识可用性与中继生态健康。若攻击者能够通过 Sybil 部署、带宽膨胀或目录破坏影响路径选择概率，即使不破解任何密码原语，也可能系统性提高自身被选入用户链路的机会。

3.3 防御技术与对抗

Tor 防御技术必须同时满足匿名性、性能、部署成本和兼容性约束。与高时延混合网络 (High-latency Mix Network) 不同，Tor 不能通过长时间批处理、强制重排序或大量固定速率填充来彻底隐藏流量时序，否则会破坏 Web 浏览等交互式应用体验。因此，本小节按照 3.2 中的攻击逻辑展开：首先讨论针对网站指纹的流量混淆，其次讨论针对去匿名化和路由级攻击的路径选择防御，再讨论洋葱服务的安全与性能改进，最后讨论面向基础设施和抗审查场景的系统级防御。

3.3.1 面向流量分析的混淆与填充防御

针对网站指纹攻击，防御思路主要包括填充 (Padding)、延迟 (Delay)、突发整形 (Burst Shaping) 和对抗扰动 (Adversarial Perturbation)。Holland 与 Hopper 提出 RegulaTor，以下载流量速率衰减模型和上传/下载比例约束重塑网页加载轨迹，并在预算范围内注入哑包 (Dummy Packet)，从而降低 WF 分类器对突发形状的利用能力 [37]。其贡献不只在降低分类准确率，更在于强调防御必须同时报告带宽开销、延迟开销和开放世界效果。Holland 等人的 DeTorrent 进一步代表了填充型防御研究向对抗式、可部署方向发展的趋势，即在尽量不改变协议主体的条件下，通过更精细的 padding 策略降低流量分析收益 [17]。

但是，流量混淆存在天然上限。若防御过弱，深度模型仍可利用剩余方向和时序模式；若防御过强，则会造成不可接受的带宽与延迟膨胀。更重要的是，攻击者可以采用自适应训练，将防御后的流量纳入训练集，使静态规则防御迅速失效。因此，针对 WF 的防御不能只追求封闭世界准确率下降，而应同时关注开放世界误报率、真实网页加载性能、长期模型漂移和部署兼容性。

3.3.2 面向去匿名化的路径选择与路由防御

针对端到端流关联、DNS 泄露和 AS/BGP 级攻击，防御重点不在于改变单个数据包内容，而在于降低攻击者同时观察通信两端的概率。守卫节点机制 (Guard Mechanism) 通过长期固定少量入口节点，降低用户在频繁随机选择入口时遇到恶意守卫的概率；出口策略和路径选择规则则避免在同一链路中选择存在明显关联关系的中继 [21]。针对 AS/BGP 级攻击，Counter-RAPTOR 提出将 AS 弹性纳入守卫选择，并结合 BGP 异常监测对路由劫持进行检测 [30]。这一思路说明，Tor 协议层防御不能只优化覆盖网络内部路径，还必须考虑底层互联网路径是否会把入口侧和出口侧同时暴露给同一观察者。

DNS 相关风险的缓解则需要同时关注出口节点配置和公共解析器集中化问题。DefecTor 揭示的关键问题并不是 Tor 链路内部加密失败，而是出口侧 DNS 解析路径为攻击者提供了额外观测信号 [29]。因此，防御方向包括减少出口侧对集中式公共 DNS 解析器的依赖、改善出口节点解析策略、在路径选

择中纳入出口侧基础设施风险，以及通过测量识别高风险解析路径。总体而言，面向去匿名化的防御应从‘单条 Tor 链路是否安全’扩展为‘客户端-守卫、出口-目的站点和 DNS/AS 路径整体是否暴露给同一观察者’。

3.3.3 面向洋葱服务的认证、测量与性能改进

针对洋葱服务攻击，防御需要同时处理应用层可用性和网络层关联风险。应用层方面，Winter 等人的用户研究说明，洋葱地址难以记忆、服务发现困难和钓鱼风险会削弱用户对洋葱服务的正确使用 [23]。因此，洋葱服务防御不仅应包括协议级加密，还应包括更可靠的地址认证、可信目录发现、用户界面提示和钓鱼检测机制。网络层方面，针对 SUMo 等会话级流关联攻击，防御方向包括更细粒度的链路填充 (Circuit Padding)、会话级流量整形、降低多路复用带来的可分离特征，以及在不显著增加时延的情况下扰乱客户端与服务端侧流量对应关系 [32]。

洋葱服务还面临突出的性能问题。DarkHorse 提出基于 UDP 的数据传输框架，试图缓解洋葱服务中 TCP-over-TCP、长路径和多轮握手带来的高延迟问题 [38]。该类方案表明，性能优化本身也是一种安全增强：更低延迟和更高可用性可以减少用户绕过安全机制或转向不可信替代服务的动机。不过，UDP 带来的乱序、丢包和路径语义变化需要与 Tor 现有链路抽象、可靠性机制和匿名性假设重新协调，因而仍需要谨慎评估其部署风险。

3.3.4 面向基础设施与抗审查的系统级防御

面对基础设施攻击，防御重点转向资源约束、带宽测量可信性和目录共识鲁棒性。Sniper Attack 之后，Tor 需要在拥塞控制、传输队列和流控窗口上限制攻击者可放大的资源消耗 [33]；TorMult 之后，带宽权威测量需要更强的抗操纵能力，避免共享资源、测量流量识别和策略性丢弃用户流量造成路径选择偏斜 [35]。目录协议方面，部分同步模型和更稳健的投票恢复机制可增强目录权威在短时 DDoS 或网络分区下的可用性 [36]。这些研究表明，Tor 匿名性不仅依赖密码学正确性，还依赖测量系统、共识协议和网络资源治理的可信性。

在抗审查方面，Tor 长期依赖可插拔传输将 Tor 流量伪装成更难被识别或更高封锁代价的协议流量。MacMillan 等人对 Snowflake 的研究表明，基于 WebRTC 的抗审查传输虽然能利用大量临时代理提高可达性，但其握手特征和流量行为仍可能与真实 WebRTC 应用存在可区分差异 [39]。Sun 与 Shmatikov 提出的差异降级攻击 (Differential Degradation Attack) 进一步说明，审查者不一定需要准确分类流量，只需制造某些网络退化条件，使规避系统性能下降而正常应用仍可接受，即可形成低成本封锁 [40]。Vilalunga 等人的 Obscura 则代表了后续方向：将流量封装进 WebRTC 媒体流，结合瞬时代理和可靠传输层，试图同时抵抗深度包检测、代理枚举和差异降级 [41]。总体看，抗审查研究已经从‘让 Tor 不像 Tor’转向‘让封锁 Tor 的代价接近封锁正常应用’。

3.4 攻防态势分析

综合现有文献，Tor 攻防态势呈现出从单点协议安全向系统级攻防博弈扩展的趋势。表1按照攻击面、代表性工作、攻击能力、对应防御和剩余问题，对当前 Tor 攻防关系进行归纳。

第一，**攻击能力从规则化走向数据驱动**。DF、Var-CNN、Tik-Tok 和 Oscar 表明，深度学习已经能够从加密流量的方向、时序和突发结构中自动提取稳定特征 [25, 26, 27, 5]；Shadbeh 等人的真实开放世界评估进一步说明，网站指纹并非纯粹实验室威胁，而可能在接近真实守卫观察者的条件下保持较高有效性 [42]。这迫使防御研究必须从封闭世界准确率转向开放世界精度、召回率、基准率、跨时间泛化和真实部署开销。

第二，**去匿名化攻击面从 Tor 覆盖网络内部扩展到底层互联网**。DeepCorr 证明入口-出口流关联可由深度模型增强 [28]，DefecTor 说明 DNS 解析基础设施会扩大出口侧观测面 [29]，Counter-RAPTOR 和后续 AS 级测量则表明 BGP 路由、自治系统路径和中继带宽集中度都会改变用户实际暴露风险 [30, 31]。因此，Tor 匿名性不能仅由三跳链路结构解释，而必须放入互联网路由、公共解析器和跨域流量监测的环境中评估。

第三，**基础设施安全成为 Tor 生态的关键瓶颈**。Sniper Attack、TorMult 和目录 DDoS 研究分别指向资源管理、带宽测量和目录共识三个核心支柱 [33, 35, 36]。攻击者若能影响这些基础设施，即使不破解任何密码原语，也可能通过改变路径选择概率、降低网络可用性或迫使用户连接恶意中继来削

表 1: Tor 网络主要攻击面与防御态势

攻击面	代表性工作	攻击能力与影响	防御思路与剩余问题
DF、Var-CNN、Tik-Tok、Oscar[25, 26, 27, 5]	利用方向、突发和时序特征识别网站或细粒度网页；深度学习降低人工特征依赖	Padding、延迟、突发整形和对抗扰动可降低识别率，但仍受带宽、时延、自适应攻击和开放世界误报率约束	DeepCorr、DefecTor、Counter-RAPTOR、AS 级测量 [28, 29, 30, 31]
同时观察入口侧和出口侧，或利用 DNS、AS/BGP 路径恢复通信关系	守卫节点、路由感知路径选择、DNS 风险测量和 BGP 异常检测可降低暴露概率，但难以抵御强 GPA 或长期多点观察者洋葱服务攻击	Onion Service 用户研究、SUMo[23, 32]	利用地址发现、钓鱼、用户认知缺陷或会话级流量关联削弱服务匿名性
地址认证、可信发现、会话级填充和性能优化是主要方向；难点在于同时保持可用性、低延迟和强抗关联能力基础设施攻击	Sniper Attack、Tor-Mult、目录 DDoS[33, 35, 36]	通过资源耗尽、带宽膨胀或目录共识中断影响中继可用性与路径选择概率	拥塞控制、带宽权威抗操纵、部分同步共识和中继生态治理可缓解风险，但部署复杂度和对现有网络兼容性仍是瓶颈抗审查对抗
Snowflake 评估、差异降级、Obscura[39, 40, 41]	审查者通过 DPI、主动探测或差异降级识别和阻断 Tor 接入流量	可插拔传输、WebRTC 封装和瞬时代理提高封锁成本；剩余问题是协议指纹、性能退化和真实应用一致性	

弱匿名性。这一趋势对于僵尸网络研究尤其重要：僵尸网络若利用 Tor 作为 C2 隐匿层，其稳定性同样依赖 Tor 中继生态和目录系统；反过来，针对 Tor 基础设施的攻击也可能影响恶意流量隐匿与防御监测的平衡。

第四，**防御研究越来越强调可部署性而非单一安全指标**。RegulaTor 和 DeTorrent 体现了低开销抗 WF 防御的工程约束 [37, 17]，Counter-RAPTOR 体现了路由安全与匿名熵之间的权衡 [30]，DarkHorse 和 Obscura 则分别从性能和抗审查角度探索 Tor 系统边界 [38, 41]。总体而言，Tor 未来演进很可能不会依赖某个单一突破，而是由路径选择、拥塞控制、流量填充、目录共识、抗审查传输和隐私保护测量的协同优化共同推动。

由此可见，Tor 网络的核心矛盾始终是低时延可用性与强匿名性之间的张力。攻击者只需在入口观测、出口观测、路由操控、流量统计或基础设施治理中的某一环节取得优势，即可显著削弱匿名性；防御者则必须在不牺牲可用性和开放部署生态的前提下，同时约束多类攻击面。这种不对称性决定了 Tor 仍将是匿名通信、安全测量和攻防博弈研究中的长期核心对象，也为后续分析僵尸网络如何借助匿名网络隐藏指挥控制、以及安全防御方如何在不侵犯正常用户隐私的条件下识别滥用行为，提供了直接的理论与技术铺垫。

4 僵尸网络匿名化与检测

僵尸，桀桀桀

5 讨论

在此讨论研究发现。

6 结论

在此撰写结论。

参考文献

- [1] S. Sasy and I. Goldberg, “Sok: Metadata-protecting communication systems,” *Proceedings on Privacy Enhancing Technologies*, 2024.
- [2] D. L. Chaum, “Untraceable electronic mail, return addresses, and digital pseudonyms,” *Communications of the ACM*, vol. 24, no. 2, pp. 84–90, 1981.
- [3] R. Dingledine, N. Mathewson, and P. Syverson, “Tor: The second-generation onion router,” 2004.
- [4] M. Shen, K. Ji, Z. Gao, Q. Li, L. Zhu, and K. Xu, “Subverting website fingerprinting defenses with robust traffic representation,” in *32nd USENIX Security Symposium (USENIX Security 23)*, 2023, pp. 607–624.
- [5] X. Zhao, X. Deng, Q. Li, Y. Liu, Z. Liu, K. Sun, and K. Xu, “Towards fine-grained webpage fingerprinting at scale,” in *Proceedings of the 2024 on ACM SIGSAC Conference on Computer and Communications Security*, 2024, pp. 423–436.
- [6] R. Jansen, R. Wails, and A. Johnson, “A measurement of genuine tor traces for realistic website fingerprinting,” in *International Conference on Passive and Active Network Measurement*. Springer, 2026, pp. 277–293.
- [7] A. M. Piotrowska, J. Hayes, T. Elahi, S. Meiser, and G. Danezis, “The loopix anonymity system,” in *26th usenix security symposium (usenix security 17)*, 2017, pp. 1199–1216.
- [8] M. Rahimi, P. K. Sharma, and C. Diaz, “Larmix: Latency-aware routing in mix networks.” in *NDSS*, 2024.
- [9] —, “Lamp: Lightweight approaches for latency minimization in mixnets with practical deployment considerations.” in *NDSS*, 2025.
- [10] I. BEN GUIRAT, D. Das, and C. Diaz, “Blending different latency traffic with beta mixing,” *Proceedings on Privacy Enhancing Technologies*, vol. 2024, no. 2, pp. 464–478, 2024.
- [11] L. Oldenburg, M. Juarez, E. A. Rúa, and C. Diaz, “Mixmatch: Flow matching for mixnet traffic,” *Proceedings on Privacy Enhancing Technologies*, 2024.
- [12] P. Scherer, C. Weis, and T. Strufe, “Provable security for the onion routing and mix network packet format sphinx,” *arXiv preprint arXiv:2312.08028*, 2023.
- [13] —, “A framework for provably secure onion routing against a global adversary,” *Proceedings on Privacy Enhancing Technologies*, 2024.
- [14] D. Chaum, “The dining cryptographers problem: Unconditional sender and recipient untraceability,” *Journal of cryptology*, vol. 1, no. 1, pp. 65–75, 1988.
- [15] C. Kocaoğullar, D. Hugenroth, M. Kleppmann, and A. R. Beresford, “Pudding: Private user discovery in anonymity networks,” in *2024 IEEE Symposium on Security and Privacy (SP)*. IEEE, 2024, pp. 3203–3220.
- [16] W. Dong, P. Jiang, H. Duan, C. Wang, L. Zhao, and Q. Wang, “Ring of gyges: Accountable anonymous broadcast via secret-shared shuffle.” in *NDSS*, 2025.
- [17] J. K. Holland, J. Carpenter, S. E. Oh, and N. Hopper, “Detorrent: An adversarial padding-only traffic analysis defense,” *arXiv preprint arXiv:2302.02012*, 2023.
- [18] T. Pulls and E. Witwer, “Maybenot: A framework for traffic analysis defenses,” in *Proceedings of the 22nd Workshop on Privacy in the Electronic Society*, 2023, pp. 75–89.

- [19] A. Sabzi, R. Vora, S. Goswami, M. Seltzer, M. Lécuyer, and A. Mehta, “{NetShaper}: A differentially private network {Side-Channel} mitigation system,” in *33rd USENIX Security Symposium (USENIX Security 24)*, 2024, pp. 3385–3402.
- [20] D. Hugenroth and A. R. Beresford, “Powering privacy: On the energy demand and feasibility of anonymity networks on smartphones,” in *32nd USENIX Security Symposium (USENIX Security 23)*, 2023, pp. 5431–5448.
- [21] The Tor Project, “Tor specifications,” <https://spec.torproject.org/index.html>, online; accessed 2026-05-28.
- [22] P. F. Syverson, D. M. Goldschlag, and M. G. Reed, “Anonymous connections and onion routing,” in *Proceedings. 1997 IEEE Symposium on Security and Privacy (Cat. No. 97CB36097)*. IEEE, 1997, pp. 44–54.
- [23] P. Winter, A. Edmundson, L. M. Roberts, A. Dutkowska-Żuk, M. Chetty, and N. Feamster, “How do tor users interact with onion services?” in *27th USENIX Security Symposium (USENIX Security 18)*, 2018, pp. 411–428.
- [24] A. Mani, T. Wilson-Brown, R. Jansen, A. Johnson, and M. Sherr, “Understanding tor usage with privacy-preserving measurement,” in *Proceedings of the Internet Measurement Conference 2018*, 2018, pp. 175–187.
- [25] P. Sirinam, M. Imani, M. Juarez, and M. Wright, “Deep fingerprinting: Undermining website fingerprinting defenses with deep learning,” in *Proceedings of the 2018 ACM SIGSAC conference on computer and communications security*, 2018, pp. 1928–1943.
- [26] S. Bhat, D. Lu, A. Kwon, and S. Devadas, “Var-cnn: A data-efficient website fingerprinting attack based on deep learning,” *arXiv preprint arXiv:1802.10215*, 2018.
- [27] M. S. Rahman, P. Sirinam, N. Mathews, K. G. Gangadhara, and M. Wright, “Tik-tok: The utility of packet timing in website fingerprinting attacks,” *arXiv preprint arXiv:1902.06421*, 2019.
- [28] M. Nasr, A. Bahramali, and A. Houmansadr, “Deepcorr: Strong flow correlation attacks on tor using deep learning,” in *Proceedings of the 2018 ACM SIGSAC conference on computer and communications security*, 2018, pp. 1962–1976.
- [29] B. Greschbach, T. Pulls, L. M. Roberts, P. Winter, and N. Feamster, “The effect of dns on tor’s anonymity,” *arXiv preprint arXiv:1609.08187*, 2016.
- [30] Y. Sun, A. Edmundson, N. Feamster, M. Chiang, and P. Mittal, “Counter-raptor: Safeguarding tor against active routing attacks,” in *2017 IEEE symposium on security and privacy (SP)*. IEEE, 2017, pp. 977–992.
- [31] G. K. Gegenhuber, M. Maier, F. Holzbauer, W. Mayer, G. Merzdovnik, E. Weippl, and J. Ullrich, “An extended view on measuring tor as-level adversaries,” *Computers & Security*, vol. 132, p. 103302, 2023.
- [32] D. Lopes, J.-D. Dong, P. Medeiros, D. Castro, D. Barradas, B. Portela, J. Vinagre, B. Ferreira, N. Christin, and N. Santos, “Flow correlation attacks on tor onion service sessions with sliding subset sum.” in *NDSS*, 2024.
- [33] R. Jansen, F. Tschorsch, A. Johnson, and B. Scheuermann, “The sniper attack: Anonymously deanonymizing and disabling the tor network,” 2014.
- [34] R. Jansen, K. S. Bauer, N. Hopper, and R. Dingledine, “Methodically modeling the tor network.” in *CSET*, 2012.

- [35] C. Sendner, J. Stang, A. Dmitrienko, R. Wijewickrama, and M. Jadliwala, “Tormult: introducing a novel tor bandwidth inflation attack,” *arXiv preprint arXiv:2307.08550*, 2023.
- [36] Z. Luo, J. Zhang, A. Neerati, and A. Kate, “Five minutes of ddos brings down tor: Ddos attacks on the tor directory protocol and mitigations,” in *Proceedings of the 21st European Conference on Computer Systems*, 2026, pp. 1314–1329.
- [37] J. K. Holland and N. Hopper, “Regulator: A straightforward website fingerprinting defense,” *arXiv preprint arXiv:2012.06609*, 2020.
- [38] M. W. Al Azad, H. Zahan, S. U. Taki, and S. Mastorakis, “Darkhorse: A udp-based framework to improve the latency of tor onion services,” in *2023 IEEE 48th Conference on Local Computer Networks (LCN)*. IEEE, 2023, pp. 1–6.
- [39] K. MacMillan, J. Holland, and P. Mittal, “Evaluating snowflake as an indistinguishable censorship circumvention tool,” *arXiv preprint arXiv:2008.03254*, 2020.
- [40] Z. Sun and V. Shmatikov, “Differential degradation vulnerabilities in censorship circumvention systems,” *arXiv preprint arXiv:2409.06247*, 2024.
- [41] A. Vilalonga, K. Gallagher, J. S. Resende, and H. Domingos, “Obscura: Enabling ephemeral proxies for traffic encapsulation in webrtc media streams against cost-effective censors,” *Proceedings on Privacy Enhancing Technologies*, 2026.
- [42] M. Shadbeh, K. Khajavi, and T. Wang, “Reality check for tor website fingerprinting in the open world,” *arXiv preprint arXiv:2603.07412*, 2026.